

Your DPDPA Compliance Roadmap

A tailored implementation plan, derived from your responses, for the Digital Personal Data Protection Act, 2023 (DPDPA).

ISSUED

May 2026

This report has been automatically generated based on your responses to the questionnaire. The content herein has not undergone independent verification or detailed review by the legal professionals at Trilegal. The objective of the report is educational and informational, and does not constitute, nor should it be construed as, legal advice or a legal opinion. The report is intended as a thought leadership and awareness tool, rather than a legal or compliance assessment. To make the observations in the report useful across a wide range of organisations and industries, the assessment relies on an "archetype model" based on the responses to the questionnaire's small foundational questions about an organisation's operations. Instead of attempting to analyse every pattern of personal data processing that may be undertaken within an organisational structure, the model identifies the most widely prevalent forms of personal data processing and uses them as reference categories. In essence, these archetypes are simplified representations designed to illustrate common regulatory engagement patterns under the DPDP framework and should therefore be understood as a directional classification, not a definitive regulatory determination, for which deeper analysis may be required. In practice, the way an organisation engages with the DPDPA typically falls within a broad and evolving spectrum. For this reason, the report should be viewed as a point-in-time interpretative snapshot based solely on the responses provided, and only as a useful starting point of increasing awareness for DPDP Act compliance. You are advised to seek legal advice before acting on any information contained in this report. Please feel free to share it with your legal advisors for further guidance. Trilegal expressly disclaims any and all liability for errors, omissions, or inaccuracies in this report or for any actions taken or not taken relying upon the contents of this report. You may contact us at PrivacyLaw@Trilegal.com.

Your DPDPA Profile

Snapshot derived from your questionnaire responses



YOUR PRIMARY ROLE UNDER DPDPA

Data Fiduciary, since you primarily determine the purpose and means of personal data of customers or users.

GEOGRAPHIC SCOPE OF PROCESSING

India

PRIMARY PERSONAL DATA TYPE

External-facing (interface with individual customers; B2C).

PERSONAL DATA PROCESSING FOOTPRINT

Low to medium.

QUICK OBLIGATIONS SNAPSHOT

- Identify the legal basis for processing personal data as under the DPDPA.
- Issue DPDPA-compliant notice and capture affirmative consent for consent-based processing.
- Build mechanisms for addressing data-principal rights.
- Build workflows to comply with prescribed retention periods.
- Map every personal data path, align vendor and intra-group DPAs in line with the DPDPA.
- Adopt reasonable security safeguards as prescribed.



IMPORTANT

This profile reflects your primary role as a data fiduciary given your processing of personal data of your individual customers or users. However, you might have additional roles for your other personal data processing activities. For instance, you will also be a data fiduciary when you process your employees' personal data or when you process personal data for recruitment. On the other hand, if you are processing personal data on behalf of a third-party (e.g., you provide software as a service to your customers), you may also be a data processor.

The DPDPA Ecosystem

Who processes what, on whose behalf, and who keeps them accountable.



PERSONAL DATA

Any data that can identify a person e.g., name, Aadhaar, biometrics.

PROCESSING

Automated operations on digital personal data and includes collection, recording, storage, adaptation, indexing, use, sharing, erasure, etc.

ECOSYSTEM ACTORS



DATA FIDUCIARY: Person who determines purpose and means (i.e., why and how personal data is processed) and bears compliance liability. Examples: bank, hospital, e-commerce platform, employer.



DATA PROCESSOR: Person who processes personal data on behalf of a data fiduciary. Primary statutory responsibility rests with the data fiduciary. Obligations are imposed mainly through data processing agreements. Examples: cloud-based SaaS providers and analytics firms.



DATA PRINCIPAL: Individual to whom the personal data relates. This includes a parent or lawful guardian acting on behalf of a child or of a person with a disability.



SIGNIFICANT DATA FIDUCIARY: Any data fiduciary or class of data fiduciaries that the Central Government may notify having regard to the nature, volume and sensitivity of the personal data processed.



DATA PROTECTION BOARD OF INDIA: Regulatory body under the Central Government. The Board was established in November 2025, though appointments remain pending and substantive operational provisions will take effect only from May 2027.



CONSENT MANAGER: Consent manager manages consent records and enables single-point interface for consent across multiple data fiduciaries.

PRIMARY LIABILITY

Data fiduciary remains primarily liable under the DPDPA.

Data processors will primarily be contractually liable and have pass-down obligations.

Exemptions that you can explore

Identify if any exemptions are available for you.



ANALOG RECORDS — DPDPA DOES NOT APPLY

Your physical records that are not converted to digital form are outside the scope of the DPDPA. For instance, paper-based visitor registers, handwritten logs, or physical filing systems maintained in analog form are outside scope.

If the same personal data is later digitised (scanned, uploaded, entered into a spreadsheet or visitor-management tool), it becomes digital personal data, and its processing must comply with the DPDPA.



PUBLICLY AVAILABLE DATA — DPDPA DOES NOT APPLY

Personal data collected from public sources that was made publicly available by the individual or pursuant to law. Example: Training your LLMs based on publicly available information.

Evaluate the overlap of collected personal data with publicly available personal data.



DATA PRINCIPALS OUTSIDE INDIA — OUTSOURCING EXEMPTION

If you are based in India and process personal data of individuals located outside India solely under contract with a foreign entity, you are exempted from *certain* provisions. Example: A global capability centre (GCC) delivering back-office services to a non-Indian group entity. DPDPA exposure may be limited in practice.

This exemption requires a defensible, documented analysis and must be re-validated whenever processes change.



IMPORTANT

As a data fiduciary, identify datasets and processing activities that are outside the scope of the DPDPA or qualify for statutory exemptions, and record them in your processing inventory with a brief rationale. Where applicable, related DPDPA obligations may be disapplied in whole or part. Revalidate this periodically, especially if the data, source, purpose or digitisation status changes.

Grounds of Processing

Consent or Legitimate Use, you will need to rely on one of these bases for processing.



Before processing any personal data, you must identify a lawful basis for such processing. The available grounds are consent and legitimate use. Each carries distinct operational requirements.

CONSENT-BASED PROCESSING

Free · Specific · Informed · Unconditional · Withdrawable.

Treat notice and consent as core product requirements.

Examples

- Sign-up flows with explicit opt-in checkboxes (unticked by default).
- Granular marketing toggles per channel (email / SMS / push).

LEGITIMATE USES

(NON-CONSENT GROUNDS)

Only if it falls within a permitted legitimate use set out in the DPDPA. If the activity does not clearly fit, rely on consent as the lawful basis.

Examples

- Employment-related processing (payroll, benefits, performance).
- Compliance with a legal obligation or lawful government request.
- Information voluntarily provided.
- Responding to a medical emergency.

YOUR OPERATIONAL REQUIREMENTS FOR BOTH GROUNDS



Document every processing activity

Record each activity processing personal data with the following: (i) purpose, (ii) lawful basis, (iii) notice/consent design, and (iv) controls to prevent purpose drift.



Build technical guardrails

Block reuse of personal data for secondary purposes unless a fresh lawful basis is established.



Change-review checkpoint

Any new feature, new personal data field, or new downstream processing must be assessed for continued fit with the relied-upon ground before launch.



WHY THIS MATTERS

The same personal dataset may be processed on different bases depending on purpose, user journey, and your role in deciding the purpose and means of processing.

Your Customer-Facing Compliance

Building the notice, consent, and grievance systems your Indian customers expect.



NOTICE

Layered, regional

CONSENT

Affirmative

USE

Purpose-bound

EXIT

Erasure, withdrawal

NOTICE & CONSENT BUILD



REFRESH YOUR PRIVACY NOTICE: In plain language cover description of personal data, purpose, grievance contact link, and data principal rights. Translate into official Indian languages.



AFFIRMATIVE CONSENT UI: Replace pre-ticked boxes with explicit opt-in. In practice, capture timestamp, purpose, and the exact notice version.



SIMPLE WITHDRAWAL: Withdrawal must be as easy as giving consent and processing must stop across all downstream systems. Can make the option available in account settings or through a dedicated email channel.

CUSTOMER RIGHTS & GRIEVANCE



PUBLISH A RIGHTS FRAMEWORK: Accessible on your website with a centralised request intake form.



OPERATIONALISE RIGHTS: Workflow to confirm request. Map personal data and logs as well as downstream systems and vendors so rights can be honoured at the system level.



GRIEVANCE TURNAROUND: 90-day statutory redressal SLA with internal escalation triggers. Track every request to closure.



WHY THIS MATTERS

Your customer-facing touchpoints will attract the highest regulatory scrutiny. A clean consent log and a working grievance pipeline are your clearest indicators of DPDPA readiness and your strongest indicators of compliance.

Your Notice & Consent Obligations

Your notice, consent, and audit requirements for your interface



Four requirements you must implement before collecting personal data.

① NOTICE REQUIREMENTS

Notice to be issued before or at collection of new personal data.

It must be standalone and not bundled with T&Cs or terms of service. Language should be plain and clear. Data principals should have the option to access it in English or any other official Indian language.* For existing personal datasets, provide notice before continued processing.

② MANDATORY CONTENT

Itemise personal data collected and the specific purposes of processing.

Should contain the communication link by which the data principal may: (i) withdraw consent at any time; (ii) exercise rights (e.g., access, correction, erasure) through the rights/grievance redressal mechanism; and (iii) complain to the Data Protection Board.

③ CONSENT STANDARD

Affirmative, recorded, withdrawable.

Consent must be a free, specific, informed and unambiguous act, and not inferred from silence. Pre-ticked boxes, risk being invalid. Withdrawal must be as easy as giving consent.

④ AUDIT LOGS

Your audit trail for compliance.

Log timestamp, notice version, and purpose at the time of consent. Consent records must be demonstrable on request. Log every withdrawal and downstream propagation event.



CONSENT RECORDS

A clean consent log is your primary record for consent-based processing. Propagate withdrawal to every processor, sub-processor, and downstream system.

*Assamese, Bengali, Bodo, Dogri, Gujarati, Hindi, Kannada, Kashmiri, Konkani, Maithili, Malayalam, Manipuri (Meitei), Marathi, Nepali, Odia, Punjabi, Sanskrit, Santali, Sindhi, Tamil, Telugu, Urdu

Data Principal Rights

The rights and operational checklist



RESPONSE WINDOW

90 days for grievances

CONSENT WITHDRAWAL

As easy as giving consent

RIGHTS COVERED

Five

RIGHTS YOU MUST HONOUR

Rights to be made available where ground of processing is consent or voluntary provision

①

INFORMATION AND ACCESS: Summary of personal data processed, and processing activities undertaken. For this, you must identify all third parties with whom personal data has been shared.

②

CORRECTION: Update inaccurate, incomplete or misleading personal data on request.

③

ERASURE: Delete personal data when requested subject to legal retention obligations.

Rights to be made available irrespective of choice of grounds (available to all data principals)

①

NOMINATION: Right to nominate another individual to exercise these rights in case of death or incapacity.

②

GRIEVANCE REDRESSAL: Readily available grievance channel providing responses within a reasonable period and not more than **90 days**.

OPERATIONAL CHECKLIST

- Single intake portal: Web form or dedicated email. Do not bury in T&Cs.
- Ensure that responses to rights requests are implemented across verticals and downstream.
- Audit log of every request, source, decision, response, and downstream propagation.



IMPORTANT

A centralised request intake form to be accessible on your website or application. Build a workflow to confirm request. Map personal data and logs as well as downstream systems and vendors so rights can be honoured at the system level.

Managing Personal-Data Lifecycle

Key requirements



How long to keep personal data, when to delete it and how to build systems that do both.

PERIOD-BASED RETENTION	ENTITY-BASED DELETION	PURPOSE-BASED DELETION
Floor of at least one year Retain personal data, associated traffic data, and processing logs for at least one year from date of processing. Erase after the one-year floor, unless retention is required by law or Government notification.	Ceiling of three years for specified classes Specified classes of data fiduciaries (see below) must erase personal data after three years of user inactivity. Notify the data principal at least 48 hours before deletion.	End of purpose, end of processing Delete on withdrawal of consent, or when the specified purpose is no longer being served, unless retention is mandated by law.

RETENTION PERIODS FOR SPECIFIC DATA FIDUCIARIES	
E-Commerce Entity ≥2 crore registered users	3 years from last user contact or activity.
Online Gaming Intermediary ≥50 lakh registered users	3 years from last user contact or activity.
Social Media Intermediary ≥2 crore registered users	3 years from last user contact or activity.

ACTION ITEMS

What to operationalise now.

① Build systems to track user inactivity across products and services.	② Automate 48-hour pre-deletion notifications to data principals.	③ Establish deletion protocols for accounts inactive for three years.	④ Ensure one-year retention of personal data, traffic data and logs , including with data processors.
--	--	---	---



TRAFFIC DATA & LOGS

Scope of "associated traffic data and processing logs" is yet to be clarified.

Securing Data & Breach Response



Key requirements

RECOMMENDED REASONABLE SECURITY STANDARDS

- Securing personal data through encryption, obfuscation, masking or use of virtual tokens mapped to personal data.
- Implement access control restrictions (e.g., RBAC).
- Maintain appropriate logs to detect access.
- Maintain back-ups of your personal data.
- Log and personal data retention (1 year).
- Data processor contractual safeguards.
- Technical & organisational measures.
- ISO 27001 likely to remain a sufficient standard.

PERSONAL DATA BREACH RESPONSE

- Without delay: Immediate notification to Board and affected individuals
- **72 hours:** More detailed notification to Board.
- No minimum threshold (every breach counts).

① DEFINING A BREACH

Any unauthorised access, use, disclosure, alteration, or destruction of personal data.

No materiality threshold for breach notification since every incident must be assessed and documented.

② NOTIFICATION TO THE BOARD

Mandatory in the manner and timeline prescribed by DPDP Rules. Must include: nature and scope, categories and volume of personal data, likely consequences, and mitigation steps taken. Data Protection Board may follow up with further directions.

③ NOTIFICATION TO DATA PRINCIPALS

Each affected individual must be notified in plain language. Must describe the breach, its likely consequences, and steps individuals can take. Cannot be waived by contract or disclaimed through prior consent.

④ PROCESSOR OBLIGATIONS

Data processors must notify the data fiduciary promptly on discovery. The data fiduciary remains solely accountable under the DPDPA. The data processor contracts must include breach SLAs, cooperation obligations, and forensic evidence access.



NO THRESHOLD FOR REPORTING: Every breach must be reported. Pre-engage legal for reporting strategy. Data processors must notify data fiduciaries without delay.

Children & Users with Disabilities



Additional obligations since you process personal data of children or persons with disabilities.

AGE-GATING AND VERIFIABLE CONSENT

- Obtain verifiable consent of the parent/guardian of such child with reference to details of identity and age.
- Ensure age-check gates cannot be easily bypassed.

OTHER RESTRICTIONS

- Identify and cease/restrict processing activities that involve tracking and behavioural monitoring in relation to children.
- Disable targeted or personalised advertising directed at a child , and any processing that is detrimental to children.

EXEMPTIONS

from verifiable parental consent and tracking / monitoring restrictions

ENTITY BASED EXEMPTION

- Educational institution for educational activities or safety of enrolled children.
- Individual data fiduciary in a crèche / day care facility for tracking and monitoring for safety of children.
- Crèche /child care centre for location tracking during travel of children.
- Clinical / mental health establishments & professionals for providing health services necessary to the child.
- Allied healthcare professionals for supporting implementation of a healthcare treatment and referral plan for the child.

PURPOSE BASED EXEMPTION

- Performing, or discharging duties in the interests of a child under Indian law.
- Issuing subsidies/benefits in the interests of a child under law or with public funds.
- Creating an account for email communication.
- Tracking a child's real-time location for safety, protection, or security;
- Preventing a child from accessing information / advertisements likely to cause harm.
- Verifying that the data principal is not a child.



PROCESSING CHILDREN'S PERSONAL DATA

Based on your responses, your platform is likely to attract under-18 users or collect their personal data. Conduct periodic audits of product features, targeting logic, and personal data uses. Engage qualified counsel to validate your age-assurance mechanism before launch.

Your Dual Role: Data Fiduciary & Data Processor

DPDPA roles are determined activity by activity. Even if you are a data fiduciary for your own operations, you may be a data processor for other activities.



A) YOU COULD BE A DATA PROCESSOR AS WELL

You can be a data processor vis-à-vis a customer/client if you process personal data on/under the instructions of your client. This is a separate activity from your own DF processing and attracts lighter compliances (mostly contractual). Common examples:

01
10

IT SERVICES & MAINTENANCE

Hosting, maintaining, or operating a client's IT systems/databases.



SAAS / CLOUD PLATFORMS

Providing cloud infrastructure that clients use to manage their customer's personal data.



ANALYTICS & REPORTING

Processing a client's customer dataset to generate dashboards or reports for the client.



MARKETING AGENCY / AD-TECH

Running campaigns using a client's customer lists and consented personal data.



BPO / CALL CENTRE

Handling your client's customer queries, transactions, or support services.



SCREENING/PAYROLL PROCESSING

Screening candidates or processing payroll/KYC entirely per client instructions.

Your Dual Role: Data Fiduciary & Data Processor

DPDPA roles are determined activity by activity. Even if you are a data fiduciary for your own operations, you may be a data processor for other activities.



B) YOUR KEY OBLIGATIONS AS A DATA PROCESSOR — WHAT CHANGES

① ACT ONLY ON INSTRUCTIONS

Process personal data only as directed by the data fiduciary/client. Do not process personal data outside the scope of the client's written instructions.

② EXECUTE A DATA PROCESSING AGREEMENT

A written DPA with the client/ data fiduciary is mandatory under the DPDPA.

③ IMPLEMENT SECURITY SAFEGUARDS

Apply reasonable technical and organisational safeguards as required under law and as per the DPA.

④ NOTIFY THE DF ON ANY BREACH

Notify the data fiduciary without delay on discovering any breach or security incident involving their personal data.

⑤ NO UNAUTHORISED SUB-PROCESSING

Do not engage sub-processors for the client's data without authorisation.

⑥ LIABILITY IS CONTRACTUAL

As a data processor, liability to data principals and the Data Protection Board does not arise directly under the DPDPA. Your exposure is contractual and flows through the DPA.



TAKEAWAY

Your data fiduciary status for your own operations does not carry over to client-instructed processing. Map every commercial arrangement: where a client fully directs the processing, treat that activity as a data processor engagement and execute a DPA. Ensure your contracts with clients correctly reflect and allocate DPDPA responsibilities.

DPDPA Penalties

As a data fiduciary, non-compliance carries Board-enforced financial penalties.



① Up to INR 50 crore.

Breach of any other provision of the DPDPA or the DPDP Rules

② Up to INR 150 crore.

Failure to observe additional obligations as a Significant Data Fiduciary.

③ Up to INR 200 crore.

Failure to observe additional obligations in relation to children.

④ Up to INR 200 crore.

Failure to notify the Data Protection Board or affected data principal of a personal data breach.

⑤ Penalty equivalent to offence.

Breach of any term of voluntary undertaking accepted by the Board. Penalty for the offence for which undertaking was given

⑥ Up to INR 250 crore.

Failure to take reasonable security safeguards to prevent breach

ENFORCEMENT

Under the DPDPA, the power to impose penalties vests exclusively with the Data Protection Board of India. The Board may inquire into breaches upon a complaint or on its own motion, and impose penalties, after affording the data fiduciary a reasonable opportunity of being heard.

The Board considers the nature, gravity, and duration of breach; number of data principals affected; intentional or negligent character; and mitigatory steps taken.

A data fiduciary may, at any stage prior to conclusion of proceedings, submit a voluntary undertaking acknowledging the breach and committing to remedial action.

Appeals against the Board orders lie before the Telecom Disputes Settlement and Appellate Tribunal.



TAKEAWAY

For violations, your organisation could face tiered penalties: from ₹250 crore for security failures, scaling down to ₹50 crore for other types of failures.

Your Compliance Roadmap

Three phases to make your organisation DPDPA-ready by May 2027



PHASE 1 • FOUNDATION

① PERSONAL DATA MAPPING

Identify every system that holds personal data and map the purposes for each dataset. This will need to be done per product / business vertical.

② GROUNDS IDENTIFICATION

Identify legal basis: consent vs legitimate use for processing.

③ APPOINT ROLES

Set roles and responsibilities across verticals and develop steps for managing the personal data.

PHASE 2 • BUILD

① NOTICE & CONSENT UI

Deploy DPDPA-compliant flows with affirmative consent and make sure that you enable consent logging.

② RIGHTS & GRIEVANCE INTAKE

Create workflows to enable data protection rights and grievance redressal mechanisms.

③ KEY DOCUMENTATION

Prepare key documents: template DPAs, privacy notices, grievance and breach responses and records showing the legal grounds for processing.

PHASE 3 • OPERATIONALISE

① RETENTION CONTROLS

Define retention schedules for all data principal categories. Configure deletion or anonymisation triggers at the end of retention period.

② SECURITY PRACTICE & DRILLS

Review and change security measures to comply with the DPDP Rules and carry out breach response testing with IT, legal, and support teams.

③ REVIEW

Assess end-to-end readiness, and make necessary changes based on market practice or regulatory updates.



IMPORTANT

The above processes will need to be replicated for each group entity, business line, or product.

Your Compliance Countdown

Three critical milestones you must keep in mind



NOV 2025



ADMINISTRATIVE MACHINERY: Data Protection Board is established and the statutory framework is in place, but is yet to be fully operationalised.

NOV 2026



CONSENT MANAGER FRAMEWORK: Consent Manager provisions take effect, and data principals gain a single-point consent mechanism across data fiduciaries.

MAY 2027



FULL SUBSTANTIVE COMPLIANCE: All notice, consent, rights, security, and retention obligations enforceable.

WHAT THIS MEANS FOR YOU

TODAY'S REGIME

Information Technology (Reasonable security practices and procedures and sensitive personal data or information) Rules, 2011 continues to govern personal data, including sensitive personal data until May 2027.

WHAT COMES NEXT

Map personal data, fix legal basis for processing, and build consent and other compliance and governance mechanisms.



TAKEAWAY

As a data fiduciary, plan a phased rollout divided by verticals, personal data capture touchpoints and products. Run workstreams in parallel since sequential execution may not meet the May 2027 deadline.